

Reconocimiento Activo y Pasivo en Auditorías Web con Python: Escaneo de Puertos y Análisis de Cabeceras HTTP

La herramienta de escaneo de puertos utiliza `socket`, módulo estándar de Python para establecer conexiones TCP a través de direcciones IP y puertos. La función `connect_ex()` se emplea para intentar una conexión; devuelve 0 si el puerto está abierto. La estructura del script recorre un rango de puertos (por ejemplo, del 20 al 1024), intenta conectarse a cada uno y reporta los que están accesibles. Se establece un timeout reducido para evitar bloqueos prolongados en puertos cerrados. Las excepciones `socket.gaierror` y `socket.error` permiten capturar errores como host inexistente o imposibilidad de conexión. Cada socket es cerrado manualmente después del intento para evitar agotamiento de recursos del sistema.

El script solicita al usuario una IP o dominio mediante `input()` y realiza el escaneo al ejecutarse el módulo. La salida se imprime directamente en consola, indicando los puertos abiertos. Esto emula un escaneo TCP básico, similar a Nmap pero limitado a detección de servicios accesibles sin identificación ni fingerprinting. Esta técnica corresponde a reconocimiento pasivo inicial en etapas de auditoría.

El analizador de cabeceras HTTP se basa en el módulo `requests`, que permite realizar solicitudes HTTP y analizar las respuestas. La función principal envía una petición GET a la URL proporcionada por el usuario, y extrae las cabeceras devueltas por el servidor. Si la URL ingresada no tiene protocolo, se antepone `http://` por defecto. Las cabeceras se procesan como un diccionario, lo que permite acceder directamente a campos clave como `Server`, `X-Powered-By`, `Content-Type`, `Set-Cookie` y `Strict-Transport-Security`.

Si la respuesta HTTP no devuelve un código 200, se imprime una advertencia indicando un estado diferente. La herramienta también puede adaptarse para resaltar ciertas cabeceras de seguridad. Por ejemplo, la presencia de `Strict-Transport-Security` indica que el servidor aplica HSTS, lo que obliga a los navegadores a comunicarse solo por HTTPS. La cabecera `Set-Cookie` puede mostrar si las cookies tienen atributos `HttpOnly` o `Secure`. `X-Powered-By` revela la plataforma del backend, útil para enumeración de tecnologías. `Content-Type` expone el tipo de contenido retornado, lo que puede revelar vectores potenciales de XSS si hay una configuración insegura. `Server` puede informar sobre el software usado (Apache, nginx, etc.).

Ambos scripts representan herramientas esenciales en fases de enumeración dentro de una auditoría de seguridad. Mientras el escáner de puertos identifica puntos de entrada disponibles en una máquina remota, el analizador de cabeceras permite extraer información crítica del servidor web sin necesidad de interactuar profundamente con el sistema. Estas herramientas deben usarse con criterio, dentro de entornos controlados o con autorización explícita, y su funcionamiento puede extenderse fácilmente con detección de banners, manejo de excepciones más robusto, o integración con bases de datos de fingerprinting.